Semana 04 — Reconocimiento, OSINT y escaneo de puertos

Fase 2: Ofensiva controlada — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	04 de 10
Fase	2 — Ofensiva controlada
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Actividad formativa
Entrega	GitHub, carpeta semana_04/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Comprobar que el repositorio del grupo tiene la carpeta semana_04 creada.
2. Revisar la retroalimentación del docente sobre la semana anterior y corregir lo pendiente.
3. Traer instaladas las herramientas de la semana: nmap como referencia, Scapy, Python dnspython, python-whois, dig, socket.
4. Confirmar que el laboratorio arranca y que los tres servicios responden antes de la sesión.
5. Leer el objetivo y los contenidos para llegar con el vocabulario de la práctica.

2 Objetivo de la semana

> Obtener información de un dominio autorizado sin generar tráfico intrusivo, descubrir hosts y escanear puertos, distinguiendo técnicas y su ruido.

3 Contenidos que se aplican

- Registros DNS A, AAAA, MX, NS, TXT y SOA.
- WHOIS y RDAP; datos del registrante y fechas de vigencia.
- Enumeración de subdominios y motores de búsqueda especializados.
- Google dorks y su uso legítimo en un alcance autorizado.
- OPSEC del auditor y protección de la identidad durante la recolección.
- Descubrimiento con ARP, ICMP y sondeo TCP a puertos comunes.
- Escaneo connect, SYN semiabierto y UDP con ICMP port unreachable.
- Estados de puerto, banner grabbing y fingerprinting.
- Sigilo, ruido y detección; límites éticos del escaneo.

4 Escenario

> Cada grupo construye un script que genere la huella digital (DNS/WHOIS) y un escáner propio, ejecutándolo contra los contenedores del laboratorio y comparando con nmap.

5 Paso a paso de la práctica

1. Definir el dominio objetivo y confirmar por escrito que es propio o autorizado.
2. Implementar la huella DNS y WHOIS con manejo de errores y salida JSON normalizada.
3. Implementar sondeos TCP connect, TCP SYN y UDP con tiempo de espera configurable.
4. Ejecutar el escáner y nmap sobre el mismo objetivo, y tabular coincidencias y diferencias.
5. Medir el tiempo por técnica, explicar los falsos positivos y concluir sobre el compromiso entre velocidad y sigilo.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_04/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: nmap como referencia, Scapy, Python dnspython, python-whois, dig, socket.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.
Grupo 2	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 3	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.
Grupo 4	**Rojo**	Evidencia cruda en semana_04/evidencia y el apartado de reproducción del informe.

7 Qué se entrega

Script integrado (huella digital + escáner), salida JSON, huella digital razonada, tabla comparativa con nmap y análisis de falsos positivos.

Estructura de la carpeta `semana_04/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_04/informe.md o informe.pdf con el entregable de esa práctica.
- semana_04/scripts/ con el código, con type hints y docstrings.
- semana_04/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_04/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.

- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Huella digital completa (DNS/WHOIS)	2,0
Escáner funcional con técnicas solicitadas	3,0
Comparación rigurosa contra nmap	2,5
Explicación técnica de falsos positivos y sigilo	1,5
Código con type hints, docstrings y manejo de errores	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_04/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit 'semana 04: <entregable>' está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
Registro DNS	Entrada de la zona que publica datos como A, AAAA, MX, NS, TXT o SOA. Es información pública y parte del reconocimiento.
WHOIS	Consulta del registro de un dominio que devuelve registrante, fechas y servidores. Se está sustituyendo por RDAP, con salida estructurada.
Enumeración de subdominios	Descubrir nombres bajo un dominio (dev, staging, vpn) para localizar servicios que no aparecen en el inventario.
Google dorks	Consultas con operadores de búsqueda que encuentran documentos y paneles indexados. Solo se usan sobre el alcance autorizado.
OPSEC	Hábitos que evitan filtrar identidad, infraestructura o intención durante la recolección de información.
Escaneo SYN	Sondeo semiabierto que no completa la conexión TCP. Es más sigiloso que connect y requiere privilegios.
Banner grabbing	Leer la cabecera que anuncia el servicio para identificar producto y versión; es la base del fingerprinting.
Fingerprinting	Inferir sistema operativo y software a partir de las respuestas, los tiempos y los detalles del protocolo.